

教會 APP 系統設計文件

版本:v1.1 更新日期:2026-07-21(新增:活動報名與簽到、禱告代禱牆)

一、市場調研摘要

1. 國際主流教會 APP 平台(2026)

平台	定位	優點	缺點	參考價格
Subsplash	媒體/直播為主的 一站式教會數位生 態系	影音串流、多校區支 援、App Store/Google Play 代管上架成熟	不含原始碼所有 權、模板化、合 約通常 12-24 個 月	約 US\$200- 500/月 + 設 定費
Church Center(Planning Center)	與 Planning Center 教會管理 系統(ChMS)深度 整合	若已用 Planning Center 做同工排班、會 友資料,銜接最順	客製化程度有 限,非獨立白牌 App	隨 Planning Center 訂閱
Pushpay / ChurchStaq	以「奉獻/什一奉 獻」為核心的平台	線上奉獻轉換率高、與 ChMS 同一資料層	偏企業用戶、費 用高,App 功能 是奉獻的附屬品	企業報價
Tithe.ly	平價/免費入門方 案	有免費層,適合小型教會	同樣模板化、無 原始碼所有權	免費起
自建(React Native / Flutter)	客製開發	完全掌握原始碼、資料 主權、UI/UX 客製自由	需要開發與維運 資源	依規模而定

趨勢觀察:2026 年的教會 App 討論越來越聚焦在「原始碼所有權」與「資料自主權」——許多教會發現用了 Subsplash/Tithe.ly 這類 SaaS 後,一旦停用合約,App 便直接從商店下架,資料難以完整匯出。若貴教會重視長期資料掌控與客製彈性(例如你提到的晨禱筆記、牧區小組這類較「個人化/內部治理」的功能),**自建或半自建(用開源 App 框架 + 自架後端)**會比直接綁定 SaaS 平台更合適。

2. 台灣教會常見作法

台灣許多教會目前仍以 **LINE 官方帳號 + 群組推播 + 教會官網** 拼裝使用,較少採用付費 SaaS 教會 App。這樣做的優點是免費、會友已熟悉 LINE;缺點是:

- 內容分散(公告在 LINE、講道影片在 YouTube、靈修文章在網站),沒有統一入口
- 無法做「個人化」功能(如晨禱筆記只給自己看、進度追蹤)
- LINE 官方帳號的訊息記錄、個資保護不在教會自己掌控範圍內

你提出的需求(晨禱靈修筆記、主日直播連結、靈修佳文分享、牧區小組介紹、牧區最新資訊)剛好是「內容整合 + 個人化工具」的組合,這正是獨立 App 相對 LINE 群發最大的價值所在。

二、功能需求規劃

核心功能(共七項)

功能	說明	建議延伸設計
1. 晨禱靈修筆記	會友每日撰寫個人靈修筆記	雲端同步、每日經文推播提醒、私人可見(預設不公開)、可選擇性分享到小組
2. 主日崇拜 YouTube 連結	顯示直播/回放連結	用 YouTube Data API 內嵌播放器,而非單純貼連結;自動抓取最新一支影片
3. 靈修佳文分享	文章型內容	後台 CMS 可由同工上稿,支援分類(如每日靈糧、牧者專欄)
4. 牧區領袖・小組介紹	靜態/半靜態資料頁	建議做成「目錄式」資料,含照片、簡介、聚會時間地點、聯絡方式(需注意個資揭露範圍)
5. 牧區最新資訊	公告/行事曆	建議與推播通知綁定,分眾發送(全教會 vs 特定牧區)
6. 活動報名與簽到	會友報名各項聚會/活動,現場掃碼簽到	詳見下方「6.1 活動報名與簽到」設計說明
7. 禱告代禱牆	會友發布/瀏覽代禱事項,互相代禱	詳見下方「6.2 禱告代禱牆」設計說明,隱私與敏感內容處理為必要項目,非選配

6.1 活動報名與簽到 — 設計說明

功能流程

- 同工在後台建立活動(名稱、時間地點、名額上限、報名截止時間)
- 會友於 App 內報名,系統即時扣減名額,額滿自動關閉或轉候補
- 活動當天由 App 產生**動態 QR Code**或由同工掃會友的**會員條碼**進行簽到
- 簽到資料回寫資料庫,供事後統計出席率、寄送感謝/回饋通知

資料設計重點

- 資料表: `events`(活動主檔)、`event_registrations`(報名記錄,含狀態:已報名/候補/已取消)、`event_checkins`(簽到記錄,含簽到時間、簽到方式)
- 簽到 QR Code 建議採**短效期動態 Token**(例如每 30 秒更新一次或活動當天才產生),避免截圖被重複使用

- 若有兒童/青少年活動報名,需有監護人同意欄位,且家長聯絡資訊要比照個資法第 8 節規則保護

資安/隱私要點

- 簽到資料屬於「行蹤/出席紀錄」,建議限制只有該活動主辦同工與系統管理員可查看名單
- 報名表單只蒐集活動所需的最少欄位,不要求非必要的個人資訊(如不需要的健康資料)

6.2 禱告代禱牆 — 設計說明(隱私與敏感內容為核心考量)

代禱牆本質上是一個「使用者產生內容(UGC)+ 個人隱私高敏感」的功能,設計上要比其他功能更謹慎,建議把隱私與內容審核當成第一優先的設計目標,而非事後補強。

發布權限與可見範圍

- 發布時提供三種可見範圍選項,並把「私人」設為預設值:
 - 私人(僅自己與代禱同工可見)
 - 小組可見(僅自己所屬牧區小組成員可見)
 - 公開(全教會會友可見)
- 允許**匿名發布**(顯示為「一位弟兄姊妹」而非真實姓名),但後台仍保留可追溯的真實身份紀錄,供濫用時稽核使用(此追溯機制需在使用條款中明確告知)

內容審核機制

- 選項一(推薦中小型教會):**發布前人工審核**,由指定同工(如代禱事工負責人)審核後才公開顯示,私人/小組可見的內容可略過審核以加快流通
- 選項二(規模較大時):先**自動內容過濾**(關鍵字/敏感詞比對,攔截明顯不當內容),公開範圍的內容仍搭配事後巡查與檢舉機制
- 提供「檢舉」按鈕,任何會友都能標記不當內容,觸發同工複核

特別敏感情境的處理

- 涉及**自傷、自殺意念、家暴、精神健康危機**等內容:不應僅視為一般代禱貼文自動公開顯示,建議設計成優先通知牧者/關懷同工的機制,而不是先讓其在牆上公開曝光
- 涉及**第三人**(如代禱內容提到某人的疾病、婚姻狀況)的貼文,建議提示發文者留意「是否已取得當事人同意分享」
- 涉及**未成年人**的代禱內容,避免公開姓名與可識別的細節

資料設計重點

- 資料表: `prayer_requests` (內容、可見範圍、是否匿名顯示、審核狀態)、`prayer_responses` (誰為此代禱、可選擇顯示或不顯示代禱人數)
- 敏感欄位(真實身份對應匿名貼文的關聯)需與一般內容分開儲存並加密,存取權限比一般內容更嚴格
- 保留刪除/下架機制,發文者可隨時自行下架已發布的代禱內容

延伸建議

- 提供資料保存期限選項(如「代禱事項 30 天後自動封存,不再公開顯示」),避免舊的敏感內容長期曝光
 - 若教會規模夠大,建議指派專責的「代禱牆管理同工」,而非交由系統管理員兼任,確保有懂牧養/關懷的人在把關內容
-

三、系統架構

(架構圖已於上方以視覺化方式呈現:使用者端 → API Gateway → 核心服務 → 資料層/外部整合)

分層說明

1. 使用者端(Client Layer)

- iOS / Android App:建議用 **React Native** 或 **Flutter** 跨平台開發,降低雙平台維護成本
- 管理後台 Web(CMS):給牧區同工上稿、管理小組資料、發推播,用一般 Web 框架(React/Vue)即可,不需要跨平台

2. API Gateway / 身份驗證層

- 統一入口,做流量控管、速率限制(rate limiting)、集中式驗證
- 身份驗證採 **OAuth2** / **OIDC**,簽發短效期 JWT + refresh token
- 角色權限(RBAC):至少分「一般會友」「小組長」「牧區同工」「系統管理員」四級

3. 核心服務層(依功能拆分,可先用模組化單體、日後視流量拆微服務)

- 靈修內容服務:晨禱筆記(個人資料,需嚴格權限隔離)與靈修佳文(CMS 上稿)
- 直播/影音服務:整合 YouTube Data API,快取最新影片資訊
- 牧區小組服務:小組、領袖資料的 CRUD
- 活動報名簽到服務:活動主檔、報名記錄、簽到記錄(動態 QR Code)
- 禱告代禱牆服務:內容發布、可見範圍控管、審核佇列、敏感內容通報(獨立於一般內容,權限更嚴格)
- 公告推播服務:整合 FCM(Android)/APNs(iOS)與可選的 LINE Notify

4. 資料層與外部整合

- 主資料庫:PostgreSQL(關聯式資料適合會友、小組、文章這類結構化內容)
 - 物件儲存:圖片、非結構化檔案(如 AWS S3 / GCP Cloud Storage,或台灣本地雲端服務)
 - 外部服務:YouTube Data API(唯讀,不需要會友帳密)、推播服務、LINE(選用)
-

四、資安規則(Security Rules)

依據 OWASP MASVS(Mobile Application Security Verification Standard)2026 版七

大類別,並對應台灣《個人資料保護法》(個資法)要求整理。晨禱筆記、會友資料、小組聯絡資訊都屬於個人資料,建議從設計初期就把資安當一級需求,而不是上線後補強。

1. 資料儲存(STORAGE)

- 裝置端不儲存明文密碼、token;使用 iOS Keychain / Android Keystore
- 個人靈修筆記等敏感內容,伺服器端資料庫欄位加密(AES-256),而非僅靠傳輸加密
- 避免把敏感資料寫入 App 的一般 log 檔

2. 加密(CRYPTOGRAPHY)

- 所有 API 溝通強制 TLS 1.3
- 密碼儲存使用 bcrypt / argon2 雜湊,不可自行設計加密演算法

3. 身份驗證(AUTH)

- 採業界標準 OAuth2/OIDC,不要自製登入機制
- Token 短效期 + refresh token 機制,登出時確實撤銷 token
- 管理後台(牧區同工/管理員登入)建議強制雙因子驗證(2FA)

4. 網路通訊(NETWORK)

- 憑證驗證(certificate validation),敏感操作(如管理後台)可加上憑證綁定(certificate pinning)
- API 層做速率限制,防止暴力破解、爬蟲抓取會友資料

5. 平台互動(PLATFORM)

- App 權限最小化原則:例如晨禱筆記功能不需要存取通訊錄,就不要申請該權限
- YouTube 影片內嵌建議用官方 embed/WebView,並限制 WebView 只能載入白名單網域
- Deep link(如推播點擊導頁)需驗證來源,避免被惡意連結利用

6. 程式碼品質(CODE)

- 定期掃描第三方套件(dependency scanning),避免用到已知漏洞的 SDK
- 不將 API 金鑰、資料庫密碼寫死在前端程式碼中,一律用後端環境變數/密鑰管理服務(如 AWS Secrets Manager)

7. 抗攻擊韌性(RESILIENCE)

- 對一般教會 App 而言,root/jailbreak 偵測、程式碼混淆的優先級較低,可視資源決定是否投入
- 較高優先級的是「防止大量帳號被枚舉」與「防止批次資料爬取」

8. 台灣個資法對應要點

- **告知義務**:註冊/使用前明確告知會蒐集哪些個人資料(姓名、聯絡方式、靈修筆記內容等)及用途
- **蒐集最小化**:牧區小組介紹頁若要顯示組員聯絡方式,建議先取得當事人同意,而非預設全公開
- **當事人權利**:提供會友查詢、更正、刪除自己資料的機制(例如帳號內建「刪除我的資料」)
- **若涉及未成年會友**(如青少年牧區、主日學),需要額外注意監護人同意機制,並避免公開未成年人姓名、照片等可識別資訊
- **資料保存與刪除**:訂定資料保存期限政策,會友離開教會或申請刪除帳號時,有明確的資料清除流程
- **代禱牆的特殊敏感資料**:代禱內容可能涉及健康狀況、家庭狀況等個資法定義的「特種個人資料」,蒐集與處理需更嚴謹的同意機制與存取控制(詳見「6.2 禱告代禱牆」)
- **活動報名的行蹤資料**:簽到記錄屬於出席/行蹤紀錄,僅限主辦同工與管理員查閱,不對一般會友公開他人出席狀態

9. 管理面資安建議

- 角色權限分級(RBAC)搭配「最小權限原則」:小組長只能編輯自己小組的資料,不能看到其他牧區的會友清單
- 後台操作留存稽核紀錄(誰在何時修改了什麼)
- 建立基本的事件應變流程(例如資料外洩時的通報與處理步驟)
- 定期備份資料庫,並實際演練復原(而不只是「有備份」)

五、建議技術棧

層級	建議技術
行動端	React Native(或 Flutter)
管理後台 Web	React / Next.js
後端 API	Node.js(NestJS)或其他你團隊熟悉的框架,搭配 REST 或 GraphQL
資料庫	PostgreSQL
物件儲存	AWS S3 / GCP Cloud Storage
推播	Firebase Cloud Messaging(跨 iOS/Android 統一介面)
影音串流	YouTube Data API v3(不需自架串流伺服器)
資安掃描	OWASP MASVS 對照表 + MobSF(免費靜態掃描工具)納入 CI/CD

六、開發階段建議

第一階段(MVP,建議 2-3 個月)

- 帳號系統(註冊/登入、角色權限)
- 主日崇拜 YouTube 連結顯示
- 靈修佳文列表與內容頁
- 牧區/小組介紹靜態頁
- 基本公告推播

第二階段

- 個人晨禱靈修筆記(含雲端同步、提醒推播)
- 後台 CMS 讓同工自行上稿,不需要工程師介入
- 分眾推播(依牧區/角色)
- 活動報名與簽到(先做人工簽到/後台名單匯出,QR Code 掃碼簽到可視資源延後)

第三階段

- 禱告代禱牆(務必先完成隱私分級與審核機制,再開放公開範圍功能,可先只上線「私人」與「小組可見」兩種範圍,公開牆與匿名機制待審核流程穩定後再開放)
- 活動報名簽到功能升級為動態 QR Code 掃碼

第四階段(視需求)

- 奉獻功能(需獨立評估金流與資安等級)
-

七、後續建議

若你已有雛型構想,下一步可以:

1. 先用 Figma 或設計工具畫出核心頁面線框圖,確認資訊架構與五大功能的呈現方式
2. 若要開始實際開發,建議先完成第一階段 MVP 並找 10-20 位會友做內測,再逐步擴充
3. 資安部分建議在正式上線前,至少跑過一次 OWASP MASVS 的基礎檢查清單(L1 等級)